

Approfondimento sulla sicurezza nelle console di gioco

Marica Bottega – VR000000, Enrico Ciciarella – VR535399

20 maggio 2026

Introduzione Lo scopo di questo elaborato è quello di analizzare come le tecniche offensive e difensive nelle console di gioco casalinghe si siano evolute nel tempo.

Il modello di minaccia all'interno del quale sono immersi questi sistemi è il **modello MATE** – *Man At The End*, ovvero quello in cui l'attaccante ha completa disposizione fisica della macchina.

Analizziamo quindi lo stato dell'arte delle tecniche di difesa impiegati dalle più grandi case produttrici di console di gioco, e di come siano comunque state prese di mira attraverso exploit software, corruzione della memoria e attacchi hardware come la *Fault Injection*, con l'obiettivo di aggirare la *Chain of Trust*.

Memory Corruption

Protezione della copia e crittografia White-Box Il contesto storico è quello dei primi anni 2000 – periodo in cui erano appena entrate in commercio console come xBox, GameCube e PlayStation 2.

Come anticipato in introduzione, il modello *MATE* assume in partenza che tutto ciò che si trova all'esterno del processore (RAM, bus di sistema, periferiche, ...) sia esposto e potenzialmente sotto il controllo dell'avversario.

Il principio è lo stesso che giustifica la crittografia White-Box: chi esegue il programma è al contempo chi può attaccarlo.

Il contributo di *Weidong Shi, Hsien-Hsin S. Lee, Chenghuai Lu e Tao Zhang*, pur non essendo specifico dell'ambito videoludico, esamina **Attacchi e analisi del rischio per i sistemi hardware a supporto della protezione della copia del software**¹ e cita tra le principali tecniche di attacco hardware per soverchiare le difese software:

- **Trace Analysis:** l'attaccante raccoglie informazioni del software protetto tramite *logging* ed analizzando le tracce d'esecuzione dello stesso. Alcune primitive sono riconoscibili anche dopo essere state cifrate (ad esempio branch condizionali, indici e diversi tipi di variabili).
- **Mod-chip:** con il termine *mod-chip* gli autori si riferiscono a dispositivi designati a mettere alla luce i meccanismi di protezione di copia. Possono anche essere destinati all'appropriazione del segnale di un altro dispositivo o a lanciare attacchi di spoofing ad altri dispositivi.
- **Emulatori:** è complesso combattere contro attacchi di emulazione senza utilizzare la cifratura; tuttavia, non è possibile parlare di protezione della copia del software se il suddetto può essere eseguito su un emulatore senza autorizzazione.

Scendendo ulteriormente nel dettaglio, gli autori analizzano anche altri contesti ed alcuni dei relativi attacchi:

¹Titolo originale: *Attacks and Risk Analysis for Hardware Supported Software Copy Protection Systems*

- Analizzando le **lazy authentication**² e le **counter-mode encryption**³, si può parlare ad esempio di **attacco ATT**, ovvero *"alter then trace attack"*, il quale prevede che l'attaccante sia in grado di modificare una parte del software (programma o dati) bit-per-bit, che le istruzioni alterate possano essere eseguite e che l'integrità di tali istruzioni/dati non venga verificata tempestivamente né in modo rigoroso istruzione per istruzione.
Il rischio delle autenticazioni "Lazy" può essere ridotto utilizzando *control flow/memory fetch address obfuscation* hardware, nonostante questo possa aumentare notevolmente l'overhead e la complessità dell'hardware stesso.
- Riguardo il **Software slice**, una tecnica che prevede di mettere in sicurezza il software proteggendone solo alcune porzioni, l'attaccante può trattare le porzioni di codice protetto come *black box* e cercare di creare un codice diverso dall'originale ma che riesca ad emettere lo stesso output dallo stesso input – naturalmente si tratta di un problema computazionale complesso se applicato a qualsiasi programma, ma l'avversario potrebbe essere interessato nel corrompere anche solo una *slice* di programma, e potrebbe riuscire a farlo in un tempo ragionevole.
- Gli autori del paper analizzano poi gli **Active Information Flow Attack**. Il contesto prevede che alcuni sistemi utilizzino lo stesso schema di cifratura e la stessa chiave sia per proteggere le istruzioni che i dati dinamici, esponendo il controllo della protezione all'utente tramite istruzioni come `enter security`, `exit security`, `secure load` e `secure store`⁴.
Vengono portati due esempi di attacco a questi sistemi: nel primo, l'attaccante può semplicemente rimpiazzare parti di codice non protetti con contenuto malevolo; dopo che il codice infetto viene criptato, l'attaccante può ridirezionare il puntatore verso tale codice per farlo eseguire in un contesto protetto. Nel secondo esempio, l'attaccante cerca di sfruttare le *linked list* per ridirezionare l'ultimo puntatore della lista ad un elemento segreto per poterlo rivelare in uno spazio non protetto. Le soluzioni a questo tipo di attacchi prevedono anche l'impiego di *program analysis* o di diverse tecniche di compilazione.
- In alcuni contesti potrebbe essere necessario utilizzare **cifrature semplici o chiavi corte**, per motivi di performance o di limitazioni hardware. Anche in questo contesto, gli autori presentano due semplici esempi di attacco, uno che mira alla derivazione di un *integrity code* breve a protezione di una porzione di codice tramite *brute force attack*, mentre l'altro che sfrutta le caratteristiche cicliche delle variabili contatore, come il fatto che incrementano in modo regolare, per individuarle (anche se cifrate – ma con una chiave corta) e ricavarne le locazioni in memoria.

Fault Injection

Architetture Moderne Riguardo l'analisi delle architetture moderne, ovvero quelle che caratterizzano le console degli anni 2020, la letteratura non offre molti approfondimenti.

I riferimenti

Fonti

²Con 'lazy' ci si riferisce alla situazione nella quale la sorgente dei dati è utilizzata come un operando ed il risultato della computazione ottenuto utilizzando dati non autenticati è in grado di modificare lo stato del processore prima che l'integrità di tali dati sia confermata.

³La counter-mode encryption (*CTR*), invece di cifrare il messaggio direttamente, si cifra una sequenza di valori numerici incrementali per produrre un flusso di bit pseudo-casuali, detto pad. Il messaggio viene poi combinato con questo pad tramite XOR, ottenendo il ciphertext. Fonte: *"Comments to NIST concerning AES Modes of Operations: CTR-Mode Encryption"*, Lipmaa et al.

⁴Rif. Table 3, *Attacks and Risk Analysis for Hardware Supported Software Copy Protection Systems*, Shi et al.